5. Seguridad y diagnóstico de problemas

5.1 Panorama general de la seguridad de la infraestructura

El análisis de seguridad del Laboratorio de Hidráulica e Hidrometeorología debe partir de una constatación central: la red bajo estudio es una infraestructura de **misión crítica 24/7/365**, cuyos productos (modelos WRF, índices de peligro de incendios, monitoreo de precipitaciones por cuenca) son consumidos en tiempo real por organismos provinciales como Defensa Civil, Bomberos y Recursos Hídricos. Una interrupción o un compromise de la red no es, por lo tanto, un incidente académico: puede afectar decisiones operativas inmediatas, como la gestión de apertura de válvulas en embalses para prevenir inundaciones urbanas.

El relevamiento físico (sección 1), el relevamiento lógico de la configuración vigente del MikroTik (sección 2), el análisis del encaminamiento (sección 3) y la descripción de los servidores y la capa de aplicación (sección 4) muestran una imagen más matizada que la de una red plana. La red actual **ya cuenta con elementos de segmentación y de mitigación**: un bridge principal CORE - VLAN AWARE, una VLAN dedicada a las cámaras de seguridad (vlan81, 192.168.81.0/24), VLANs asociadas a la conectividad del proveedor (vlan381 y vlan900) y al segmento público, redes dedicadas para cálculo (10.0.1.X), control de clúster (10.20.0.X) y SAN de bases de datos (10.90.0.X), y acceso administrativo mediante túneles VPN que evita exponer puertos de gestión como SSH.

Sin embargo, entre esa segmentación puntual y una arquitectura segura media una distancia considerable. Los pilares sobre los que se apoya hoy la seguridad siguen siendo frágiles:

1. **Un único dispositivo perimetral multipropósito.** El router MikroTik **CCR2116-12G-4S+** concentra el enrutamiento, la conmutación de distribución, el servidor DHCP y el firewall perimetral. No existe defensa en profundidad: cualquier error de configuración o vulnerabilidad de RouterOS expone directamente todos los servicios internos, y no se relevó un segundo equipo de borde ni un mecanismo de alta disponibilidad perimetral.
2. **Segmentación incompleta y asimétrica.** Las funciones con motivación operativa (cámaras, proveedor, SAN, Heartbeat) fueron separadas, pero los segmentos con mayor valor crítico no: la LAN privada principal (172.16.48.0/24) convive sobre el mismo bridge con las redes móviles (192.168.85.0/24 Android y 192.168.86.0/24 iOS) y, según el relevamiento físico, con las interfaces IPMI/iLO de los servidores. Como advierte la sección 2, la existencia de subredes distintas no equivale a VLANs distintas.
3. **Encaminamiento sin redundancia ni verificación.** La sección 3 documenta que no se verificaron rutas estáticas ni el uso de OSPF/BGP, y que no existe un mecanismo propio de cambio automático entre dos enlaces. Con un único enlace institucional y un solo router principal, ningún protocolo dinámico resolvería la interrupción que produciría la falla de cualquiera de ellos.

En términos del modelo de defensa en profundidad, la red tiene esencialmente **una capa de control consistente** (el firewall del MikroTik) más una serie de separaciones puntuales que se comportan como separadores de tráfico más que como fronteras de seguridad: todo el encaminamiento entre subredes, cuando está permitido, atraviesa el mismo y único dispositivo, y las reglas que gobiernan esos pasos no fueron verificadas durante el relevamiento.

5.2 El firewall del MikroTik y sus limitaciones

El firewall perimetral está implementado mediante las funciones de filtrado de RouterOS en el CCR2116-12G-4S+. RouterOS es una plataforma flexible que permite construir reglas de filtrado, NAT y colas con granularidad fina, y el hardware brinda capacidad de sobra para el volumen de tráfico actual. Las limitaciones identificadas son estructurales y no de capacidad:

a) Firewall por software en un dispositivo saturado de roles. El mismo equipo que inspecciona paquetes también enruta entre seis o más subredes, conmuta el bridge principal, publica el segmento de direcciones públicas y sirve DHCP. Un error en la política de firewall del bridge afecta a todas las VLANs simultáneamente. Además, como explica la sección 3, el tráfico que atraviesa el equipo se distingue del dirigido al propio router: revisar esa distinción en las reglas de filtrado es imprescindible para no confundir protección del router con protección de la red.

b) El perímetro no ve el tráfico que más importa. El punto de entrada principal de la red es el puerto TCP 443 hacia Traefik, que realiza la terminación del cifrado TLS. Para el firewall del MikroTik, toda esa actividad se reduce a "conexiones TLS hacia Traefik": el contenido viaja cifrado, de modo que la inspección posible a nivel de capas 3 y 4 no alcanza a examinarlo. No se relevó inspección de aplicaciones ni detección/preención de intrusiones (IDS/IPS) que pudiera compensarlo. Esta característica, que se desarrolla en detalle en 5.3.2, no es una deficiencia de RouterOS sino una consecuencia arquitectónica: el único punto del laboratorio donde el tráfico web se descifra queda detrás de la única frontera de la red.

c) Direccionamiento público directamente sobre el bridge. El bloque público /29 del laboratorio figura asociado al bridge principal, junto con la vlan2. La sección 2 advierte que, sin la tabla de VLAN del bridge, no es posible afirmar que el tráfico público esté efectivamente separado a nivel de enlace de la red interna.

d) Dependencia de terceros. La salida externa se canaliza por la PSI y el proxy central de la UNC, la resolución del dominio propio ohmc.ar depende de un DNS gestionado externamente (CloudNS), y durante el relevamiento se mencionaron dificultades de acceso a ciertos destinos que debieron resolverse con intervención de la UNC. Cada uno de estos servicios es un componente de la cadena de disponibilidad sobre el que el laboratorio tiene control o visibilidad limitados, sin acuerdos de nivel de servicio documentados.

En síntesis, la limitación fundamental no es la capacidad bruta del CCR2116, sino **arquitectónica**: confiar el perímetro, el encaminamiento entre todos los segmentos y el firewall de una red crítica a un único dispositivo, sin capas adicionales, sin redundancia y sin documentación verificable de las reglas.

5.3 Exposición de servicios, aislamiento y red de administración IPMI

5.3.1 ¿Qué es una DMZ y por qué importa en esta red?

Las secciones anteriores mencionan la DMZ como objetivo de la mejora proyectada, pero conviene definir el concepto antes de usarlo como criterio de diagnóstico.

DMZ significa *DeMilitarized Zone* (zona desmilitarizada). Es un segmento de red intermedio, separado tanto del exterior como de la red interna, donde se ubican únicamente los servicios que deben estar expuestos a usuarios externos: en el caso del laboratorio, el proxy inverso Traefik y los front-end web. El nombre proviene de la analogía con las zonas tampón entre países: territorio donde se admite contacto con el exterior, pero sin acceso al interior.

Su función no es evitar los ataques, sino **acotar sus consecuencias**. En una arquitectura con DMZ, un atacante que comprometa un front-end queda contenido dentro de esa zona: para alcanzar las bases de datos o el almacenamiento tendría que superar una segunda frontera (el filtrado entre la DMZ y la red interna), que se configura de forma mínima, por ejemplo, permitiendo solo las consultas de los contenedores web hacia el puerto específico de la base de datos y nada más. Cada paso adicional que un atacante debe dar es una oportunidad de detectarlo y detenerlo; a eso se refiere el principio de defensa en profundidad.

Aplicado al laboratorio, el criterio de diagnóstico es directo: los servicios expuestos (Traefik y contenedores web) y los datos más sensibles (las bases de datos PostgreSQL/PostGIS de Kumara y el almacenamiento YakuNAS de 180 TB) **comparten hoy la misma infraestructura lógica**. No existe la zona intermedia. La sección 3 lo reconoce al señalar que el segmento actual de publicación se diferencia de la DMZ con mayor aislamiento que se plantea implementar. En consecuencia, no hay segunda frontera: el aislamiento entre un eventual compromiso del front-end y los datos de producción depende únicamente de que las propias aplicaciones y contenedores estén correctamente configurados, sin que la red ayude a contener el incidente.

Cabe evitar el alarmismo: materializar el escenario requiere una cadena de fallos (una vulnerabilidad explotable, un contenedor mal configurado y ausencia de detección), y su probabilidad cotidiana es baja. Pero el impacto potencial es la pérdida de las bases de datos que alimentan a organismos de emergencia, y el costo de mitigarlo es de los más bajos de todo el diagnóstico: crear la DMZ es, esencialmente, ubicar los front-end en una VLAN propia y escribir las reglas de filtrado hacia producción, reutilizando el equipamiento administrable existente. Cuando el impacto es alto y el costo de la salvaguardia es bajo, la mejora se justifica aunque el escenario sea poco probable.

5.3.2 La concentración del tráfico en Traefik

Traefik es el componente que recibe todo el tráfico web del exterior: escucha en el puerto 443, termina el cifrado TLS y, según el nombre de host solicitado, enruta cada petición hacia la IP privada del contenedor Docker correspondiente. El diseño es correcto en su lógica: un único punto de entrada filtrado y balanceado. El problema no es el software sino la **geometría de la red** que lo rodea, y se puede descomponer en tres consecuencias:

Primera: el perímetro no inspecciona el tráfico que transporta. Como se anticipó en 5.2.b, el firewall del MikroTik solo ve conexiones TLS cifradas hacia Traefik. Todo el escrutinio real del tráfico web (cabeceras HTTP, nombres de host, contenido de las peticiones) ocurre dentro de Traefik, detrás de la única frontera de la red. La seguridad del tráfico entrante descansa por completo en la configuración de Traefik y de los contenedores que este alcanza, sin que exista una capa de red que la respalde.

Segunda: un solo punto concentra la superficie de ataque expuesta. Traefik termina el TLS, gestiona los certificados, interpreta cabeceras HTTP y decide qué contenedor interno atiende cada solicitud. Cualquier vulnerabilidad en Traefik, en un contenedor web o en la gestión del certificado otorga al atacante presencia directa en la red interna, sin capas intermedias que lo contengan. Esto es exactamente lo que la DMZ de la sección 5.3.1 está diseñada para amortiguar.

Tercera: los contenedores web ya tienen vista de producción. Los contenedores del clúster Proxmox consultan de forma bidireccional las bases de datos de Kumara a través de la SAN de 10 Gb/s. Un contenedor comprometido no necesita "entrar" a producción: ya opera en posición de alcanzarla. De nuevo, la red no aporta aquí ninguna frontera; la contención depende solo del propio software.

Ninguna de estas tres observaciones impugna el uso de Traefik, que permanece como componente central del diseño, también en la arquitectura mejorada de la sección 6. Lo que impugnan es su **ubicación**: un punto con estas responsabilidades debería residir en una zona aislada, con las reglas de salida hacia producción reducidas al mínimo necesario.

5.3.3 Aislamiento interno: segmentación parcial, fronteras incompletas

La LAN privada 172.16.48.0/24 es un **dominio de confianza compartido** por dispositivos con niveles de exposición muy distintos: servidores de producción con direcciones fijas, estaciones de trabajo con DHCP, interfaces IPMI y, a través del bridge, las redes móviles de teléfonos. Los enlaces aislados por diseño (la red 10.0.1.X del clúster Yaku tras su conmutador exclusivo, la SAN 10.90.0.X y la red Heartbeat 10.20.0.X) demuestran que el aislamiento se aplicó cuando hubo una motivación de rendimiento o de failover, pero no como política sistemática de seguridad.

Dos casos ilustran esta asimetría:

- **Cámaras de seguridad.** Cuentan con VLAN propia (vlan81), lo que es un ejemplo positivo. Sin embargo, no se pudo confirmar la existencia de reglas que impidan que la vlan81 inicie tráfico hacia la LAN privada, que es el riesgo clásico de los dispositivos IoT. La separación existe a nivel de enlace; la frontera a nivel de firewall no fue verificada. La sección 3 registra, además, la propuesta pendiente de trasladar el tráfico interno de Proxmox a ese mismo switch separado por VLANs: una reorganización razonable que reforzaría la separación de capa 2, pero que requerirá reglas de encaminamiento y permisos explícitos.

- **Redes móviles.** Las subredes Android e iOS están definidas sobre el mismo bridge que la LAN privada, y la sección 3 explica que la separación se realizó por agotamiento de direcciones, no por seguridad. El NAT desde ese Wi-Fi hacia la red interna no está implementado; se lo mencionó solo como posibilidad futura. Esa propuesta debería evaluarse con cautela: habilitar accesos móviles hacia servicios internos en una red sin segmentación estricta aumenta la superficie expuesta en lugar de reducirla.

5.3.4 La red de administración y la IPMI: riesgo crítico, con una mitigación importante

El hallazgo más severo del relevamiento de campo sigue siendo la falta de aislamiento de la red de administración fuera de banda (IPMI/iLO): las placas de control remoto de los servidores críticos **extraen direcciones del segmento general**, sin VLAN de administración ni firewall intermedio.

El análisis de la capa de aplicación (sección 4) matiza el alcance del riesgo: el laboratorio emplea **túneles VPN** para las tareas de administración, el mantenimiento y las conexiones SSH, incluidas las interfaces IPMI. La IPMI no está, por lo tanto, expuesta directamente a Internet: el acceso administrativo se realiza con cifrado y sin publicar puertos de gestión en el perímetro. Es una mitigación valiosa y debe reconocerse como tal.

No obstante, la mitigación opera sobre el **camino de acceso**, no sobre la **ubicación de las interfaces**. La IPMI opera por debajo del sistema operativo: un atacante que alcance una placa puede encender, apagar, reiniciar o reinstalar el sistema del servidor, eludiendo los controles del sistema operativo. La VPN protege el acceso legítimo, pero no impide que un equipo ya comprometido dentro de la LAN privada escanee y ataque las placas IPMI directamente, porque estas siguen conviviendo en el segmento general. A ello se suman las debilidades habituales de estas plataformas: credenciales por defecto, firmwares desactualizados y superficies de ataque documentadas (consola KVM remota, montaje de imágenes ISO), sin que se haya relevado una política de actualización de firmware de BMC. Un apagado remoto masivo desde una posición interna sigue siendo un ataque de disponibilidad total sobre un laboratorio 24/7, sin necesidad de atravesar el firewall perimetral ni la VPN.

En resumen: la VPN reduce la exposición exterior a un vector de movimiento lateral interno. La solución de fondo sigue siendo aislar la IPMI en una VLAN de administración dedicada, accesible únicamente desde los equipos y redes de gestión, combinada con la VPN ya existente.

5.3.5 Diagrama de zonas de confianza y exposición

El siguiente esquema sintetiza el diagnóstico: cada bloque representa una zona de confianza y las flechas indican los caminos de tráfico confirmados o no verificados. La ausencia de la zona intermedia descrita en 5.3.1 es visible en el esquema: no existe ningún bloque entre el borde y los servidores de datos.

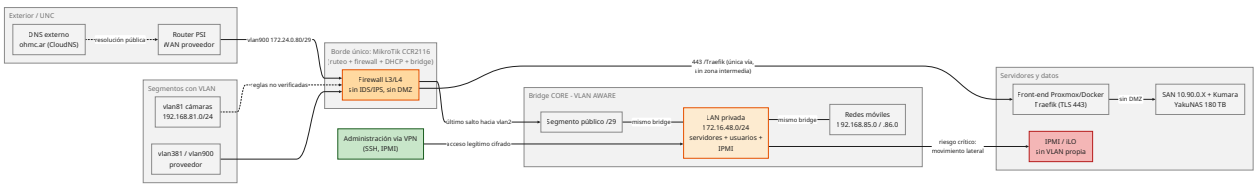


Figura 5.1: Zonas de confianza de la red actual. En rojo, el riesgo crítico de la IPMI compartiendo segmento con usuarios (el acceso legítimo por VPN, en verde, no mitiga el movimiento lateral); en naranja, las fronteras no verificadas (segmento público sobre el bridge y reglas de la vlan81). El firewall del MikroTik es la única frontera consistente.

5.4 Disponibilidad y posibles puntos únicos de falla

La disponibilidad continua es un requisito institucional explícito. El cruce de los cuatro relevamientos identifica múltiples puntos únicos de falla (SPOF):

Componente / elemento	Función	Consecuencia de su falla
Enlace WAN del proveedor (vlan900, fibra ~1 Gbit/s)	Única salida externa	Pérdida total de la publicación de servicios y del acceso externo; sin enlace alternativo ni failover automático.
MikroTik CCR2116 de borde	Ruteo + firewall + DHCP + bridge	Caída simultánea de las cuatro funciones; toda la red queda inoperativa, incluida la comunicación entre VLANs.
Bridge CORE - VLAN AWARE	Interconexión lógica de los segmentos	Una misconfiguración o un loop afecta a todas las VLANs a la vez.
DNS externo (ohmc.ar, CloudNS)	Resolución de los servicios públicos	Sin resolución DNS, los servicios siguen activos pero son inalcanzables por nombre para los usuarios externos.
Switch de la SAN (10 Gb/s)	Único enlace Proxmox-Kumara	Sin SAN, las consultas a las bases de datos PostgreSQL/PostGIS de producción colapsan aunque los servidores sigan operativos.
Nodo máster Yaku	Orquestación del clúster de cálculo	Sin máster no hay corridas de WRF programables, aunque los esclavos estén sanos; el acceso a los nodos requiere pasar por el máster.
Alimentación eléctrica del shelter	Energía de todos los racks	No se relevó UPS redundante ni grupo electrógeno; un corte prolongado detendría el servicio 24/7.

Cabe resaltar que la capa de servicios sí está diseñada para la resiliencia: la red Heartbeat permite el traslado automático de contenedores entre nodos Proxmox ante fallas de hardware, y la SAN evita cuellos de botella de disco. Pero la capa de red que la sostiene no lo está: una falla del CCR2116, del enlace WAN o del switch SAN derriba incluso los servicios virtualizados redundantes. La sección 3 lo formula con precisión: si se mantiene un único enlace institucional y un solo router principal, incorporar un protocolo de encaminamiento dinámico no resuelve la interrupción que produciría la falla de cualquiera de ellos.

5.5 Matriz de riesgos y problemas identificados

El siguiente cuadro consolida los riesgos detectados a partir de los cuatro relevamientos, los evalúa cualitativamente (probabilidad × impacto) y propone una línea de solución que se desarrolla en la sección 6:

N.º	Riesgo / problema	Probabilidad	Impacto	Solución propuesta
R1	IPMI/iLO en la LAN privada sin VLAN propia; movimiento lateral posible desde cualquier equipo interno comprometido (el acceso vía VPN protege solo el camino exterior)	Media	Crítico	VLAN de administración dedicada, accesible solo desde red/host de gestión, combinada con la VPN existente
R2	Firewall por software único en el CCR2116, sin redundancia ni inspección profunda	Media	Alto	Firewall dedicado (NGFW) en perímetro con HA; CCR2116 reasignado a ruteo/distribución
R3	Bloque público /29 sobre el mismo bridge que la LAN privada, sin separación verificada a nivel de enlace	Media	Alto	VLAN dedicada para el segmento público y revisión de la tabla de VLAN del bridge
R4	Subredes móviles (Android/iOS) sin VLAN propia: conviven con la LAN privada en el mismo dominio	Alta	Medio	VLANs específicas para móviles/ invitados con reglas de acceso restringidas
R5	Ausencia de DMZ implementada: front-end web en la misma infraestructura lógica que bases de datos y almacenamiento	Media	Alto	DMZ para Traefik y front-end; filtrado estricto DMZ hacia producción (ya planteada como objetivo)
R6	Reglas entre vlan81 (cámaras) y LAN privada no verificadas; riesgo típico de dispositivos IoT	Media	Medio	Reglas por defecto deny entre vlan81 y producción; documentación de la política inter-VLAN
R7		Media	Crítico	

N.º	Riesgo / problema	Probabilidad	Impacto	Solución propuesta
	SPOF del enlace WAN y del borde, sin failover automático ni protocolo dinámico que pueda compensarlo			Segundo enlace WAN o acuerdo de contingencia con la PSI; redundancia del equipo de borde
R8	Nodo máster Yaku, switch SAN y DNS externo (CloudNS) como dependencias únicas	Media	Alto	Replicar orquestación; segundo enlace SAN; proveedor DNS secundario o local
R9	Firmware/credenciales de BMC y switches sin gestión centralizada; configuraciones sin respaldo documentado ni verificación de rutas	Alta	Medio	Inventario de activos, hardening, respaldo y auditoría periódica de configuraciones
R10	Dependencia del proxy UNC, la PSI y el DNS externo sin SLA ni escalamiento documentado	Baja	Medio	Acuerdos con PSI/terceros; rutas de escalamiento ante incidentes

5.5.1 Priorización y lectura del diagnóstico

Ordenados por severidad, los tres riesgos que exigen intervención inmediata son **R1 (IPMI)**, **R7 (SPOF perimetral)** y **R2 (firewall único)**, porque combinan alta criticidad institucional con rutas de ataque o de falla sencillas. Es significativo que R1 sea también el de **menor costo relativo de mitigación**: aislar la red IPMI en una VLAN requiere hardware administrable y configuración, no una inversión proporcional al riesgo que elimina, y la VPN ya existente quedaría como segunda capa en lugar de único control.

Los riesgos R3 a R6 conforman el segundo escalón y comparten una misma raíz: la segmentación existe, pero **incompleta y sin fronteras verificadas**. La documentación de la tabla de VLAN del bridge y de las reglas inter-VLAN, señalada como dato faltante en las secciones 2 y 3, es una tarea de diagnóstico con impacto directo de seguridad: completar ese mapa permitiría confirmar o descartar los caminos marcados como no verificados en la Figura 5.1.

Finalmente, los riesgos R8 a R10 son de naturaleza **organizativa y de gestión** (inventarios, políticas, acuerdos, respaldos) y pueden encararse en paralelo sin esperar la adquisición de equipamiento.

En conclusión, el diagnóstico es claro: el laboratorio posee un núcleo de servicios bien diseñado, ha comenzado a segmentar su red y ha incorporado mitigaciones valiosas como la VPN administrativa, pero sostiene esa capacidad crítica sobre un perímetro único, un bridge compartido por segmentos de confianza muy distinta, redes de administración sin VLAN propia y dependencias externas sin respaldo. Los hallazgos de esta sección justifican técnicamente el rediseño que se presenta a continuación, orientado a incorporar defensa en profundidad (firewall dedicado, DMZ, segmentación estricta por VLAN), aislar la red fuera de banda IPMI y eliminar los puntos únicos de falla identificados.